

# CISM

*Certified Information Security Manager*

ISACA · Global Certification · Information Security Management

# 300

Interview Questions  
& Answers

*With Real-World Examples*

|    |                                 |     |
|----|---------------------------------|-----|
| 01 | Information Security Governance | 17% |
| 02 | Information Risk Management     | 20% |
| 03 | Information Security Program    | 33% |
| 04 | Incident Management             | 30% |

# Table of Contents

CISM – Certified Information Security Manager | 300 Questions & Answers

300 Questions  
All 4 Domains

D1

Governance

17%

40 Q

D2

Risk Mgmt

20%

40 Q

D3

IS Program

33%

53 Q

D4

Incident Mgmt

30%

53 Q

## CONTENTS

01

### Information Security Governance

Q1–Q40 · Policies · COBIT · CISO Role · KPIs · Risk Appetite

40 Q

02

### Information Risk Management

Q41–Q80 · Risk Assessment · BIA · DREAD · STRIDE · Threat Intel

40 Q

03

### Information Security Program

Q81–Q133 · IAM · Encryption · DevSecOps · SIEM · Cloud Security

53 Q

04

### Incident Management

Q134–Q186 · IR Phases · BCP/DRP · Forensics · GDPR · Playbooks

53 Q

05

### Bonus: CISM Exam Tips & Strategy

Q187–Q300 · Exam Format · CPE Requirements · Ethics · Approach

10 Q

## Domain 1: Information Security Governance (17%)

Q1.

What is Information Security Governance?

**Answer:** It is the framework of policies, processes, and controls that directs and controls an organization's information security activities to achieve business objectives and manage risks.

*Example:* A bank's board approves an IS governance framework aligning cybersecurity investments with Basel III compliance requirements.

---

Q2.

What are the five outcomes of IS Governance?

**Answer:** Strategic alignment, risk management, value delivery, resource management, and performance measurement.

*Example:* A CISO presents a quarterly dashboard showing all five governance outcomes to the board of directors.

---

Q3.

What is the role of the board of directors in IS Governance?

**Answer:** They provide oversight, approve IS strategy, ensure adequate resources are allocated, and hold senior management accountable for security performance.

*Example:* The board reviews and approves the annual cybersecurity budget and risk appetite statement.

---

Q4.

What is a Security Steering Committee?

**Answer:** A cross-functional group responsible for overseeing IS governance, aligning security initiatives with business goals, and making key security decisions.

*Example:* The steering committee approves a new BYOD policy affecting 5,000 employees across three business units.

---

Q5.

What is the difference between governance and management in IS?

**Answer:** Governance sets direction, defines policies, and ensures accountability; management implements, operates, and monitors controls to achieve governance objectives.

*Example:* The board (governance) sets the risk appetite; the CISO (management) implements the controls to stay within that appetite.

---

Q6.

What is an Information Security Strategy?

**Answer:** A plan that aligns IS objectives with business goals, defines roadmap to manage risk, comply with regulations, and protect information assets over a multi-year period.

*Example:* A 3-year IS strategy document outlines cloud adoption security, zero-trust implementation, and GDPR compliance milestones.

---

Q7.

What is risk appetite in IS Governance?

**Answer:** The amount and type of risk an organization is willing to accept in pursuit of its business objectives.

*Example:* A fintech firm defines its risk appetite as tolerating no more than 0.1% annual data breach probability for customer financial data.

---

Q8.

What is a Security Policy?

**Answer:** A high-level document that states management's intent and direction for protecting information assets and defines responsibilities.

*Example:* An Acceptable Use Policy (AUP) defines how employees may use corporate email and internet resources.

---

Q9.

What is the difference between a policy, standard, procedure, and guideline?

**Answer:** Policy: high-level intent. Standard: mandatory requirements. Procedure: step-by-step instructions. Guideline: recommended best practices (not mandatory).

*Example:* Policy: 'Data must be encrypted.' Standard: 'Use AES-256.' Procedure: 'Configure BitLocker using these steps.' Guideline: 'Consider hardware tokens for admin accounts.'

---

Q10.

What is the CISO's primary responsibility in governance?

**Answer:** To develop, implement, and maintain the IS strategy, ensure alignment with business objectives, manage the IS team, and communicate security posture to executive leadership.

*Example:* The CISO presents a risk scorecard to the CEO and board quarterly, highlighting top threats and program maturity levels.

---

Q11.

What are Key Performance Indicators (KPIs) in IS Governance?

**Answer:** Measurable values that demonstrate how effectively an organization is achieving key security objectives.

*Example:* KPI: 'Mean Time to Detect (MTTD) < 24 hours' measures the efficiency of the threat detection capability.

---

Q12.

What are Key Risk Indicators (KRIs) in IS Governance?

**Answer:** Metrics used to signal increasing risk exposure before an incident occurs, enabling proactive risk management.

*Example:* KRI: 'Number of unpatched critical vulnerabilities > 10' triggers an escalation to senior management.

---

Q13.

What is a Business Case for Security Investment?

**Answer:** A formal justification of security spending that aligns investment with business value, quantifies risk reduction, and demonstrates ROI to decision-makers.

*Example:* A business case for SIEM implementation shows \$2M potential breach cost avoidance vs. \$400K annual tool cost.

---

Q14.

What is the concept of 'security as a business enabler'?

**Answer:** Viewing security not only as a cost center but as a function that enables business growth by building customer trust, enabling secure digital transformation, and meeting compliance requirements.

*Example:* An e-commerce company's ISO 27001 certification helps win enterprise contracts requiring ISMS proof of compliance.

---

Q15.

What is the IS Governance maturity model?

**Answer:** A framework (often based on CMM or COBIT) that measures the maturity of an organization's IS governance from Initial (ad hoc) to Optimizing (continuously improving).

*Example:* An organization scores Level 2 (Repeatable) and creates a roadmap to achieve Level 4 (Managed) within 18 months.

---

Q16.

What is COBIT and its relevance to IS Governance?

**Answer:** COBIT (Control Objectives for Information and Related Technologies) is a framework by ISACA for IT governance and management, ensuring IT is aligned with business goals and risks are managed.

*Example:* An organization uses COBIT 2019 to define governance objectives for cybersecurity and maps controls to ISO 27001.

---

Q17.

What is a Balanced Scorecard in IS context?

**Answer:** A strategic planning tool that evaluates IS performance across four perspectives: Financial, Customer, Internal Process, and Learning & Growth.

*Example: The IS balanced scorecard shows 95% patch compliance (internal process), 2% phishing click rate improvement (learning), and zero regulatory fines (financial).*

---

Q18.

What is the principle of least privilege?

**Answer:** Users and systems should have only the minimum access rights necessary to perform their functions, reducing the attack surface.

*Example: A database administrator is granted read-write access only to the specific databases they manage, not the entire server.*

---

Q19.

What is segregation of duties (SoD)?

**Answer:** A control that divides critical tasks among multiple individuals to prevent fraud and errors by ensuring no single person controls an entire process.

*Example: In a financial system, the person who initiates a payment cannot be the same person who approves it.*

---

Q20.

What is due care and due diligence in IS?

**Answer:** Due care: taking reasonable steps to protect assets (doing the right thing). Due diligence: thoroughly assessing risks and understanding obligations before acting.

*Example: Due diligence: conducting a vendor security assessment before signing a cloud contract. Due care: implementing MFA and encryption after onboarding.*

---

Q21.

What is the concept of information ownership?

**Answer:** Information owners are business leaders responsible for classifying, defining access rules, and ensuring appropriate protection of information assets under their custody.

*Example: The HR Director is the information owner for employee personal data and approves access requests to the HRMS.*

---

Q22.

What is an IS Charter?

**Answer:** A formal document that establishes the IS function's authority, mission, scope, responsibilities, and reporting structure within an organization.

*Example: The IS Charter grants the CISO authority to enforce security policies across all business units and report directly to the board.*

---

Q23.

What is the role of internal audit in IS Governance?

**Answer:** To independently assess the effectiveness of IS controls, governance frameworks, and compliance, providing assurance to the board and management.

*Example:* Internal audit reviews the access management process and identifies that 15% of terminated employee accounts were not disabled within policy SLA.

---

Q24.

What is the three lines of defense model?

**Answer:** 1st Line: Business units own and manage risks. 2nd Line: Risk/Compliance functions oversee and monitor. 3rd Line: Internal audit provides independent assurance.

*Example:* The network team (1st) patches systems; the security team (2nd) verifies patch coverage; internal audit (3rd) validates the patching process annually.

---

Q25.

What is regulatory compliance in IS Governance?

**Answer:** Ensuring the organization's IS practices meet applicable laws, regulations, and contractual obligations (e.g., GDPR, HIPAA, PCI DSS).

*Example:* A healthcare provider maps its IS controls to HIPAA Security Rule requirements and documents evidence for annual compliance reviews.

---

Q26.

What is the importance of IS Governance metrics?

**Answer:** Metrics provide evidence of control effectiveness, enable data-driven decisions, demonstrate accountability to stakeholders, and identify areas needing improvement.

*Example:* Monthly metrics showing a 40% reduction in phishing success rate validate the effectiveness of security awareness training investments.

---

Q27.

What is a security culture?

**Answer:** The shared values, beliefs, and behaviors within an organization that support and prioritize information security as everyone's responsibility.

*Example:* A company with a strong security culture sees employees voluntarily reporting suspicious emails rather than just following mandatory reporting procedures.

---

Q28.

What is an IS governance framework?

**Answer:** A structured set of guidelines, standards, and best practices that organizations use to implement and manage IS governance (e.g., ISO 27001, NIST CSF, COBIT).

*Example:* An organization adopts the NIST Cybersecurity Framework as its IS governance framework, mapping current controls to the Identify-Protect-Detect-Respond-Recover categories.

---

Q29.

What is the concept of accountability in IS Governance?

**Answer:** Ensuring that individuals and teams are answerable for their IS responsibilities, actions, and outcomes through defined roles and reporting mechanisms.

*Example:* The IS governance structure assigns accountability for cloud security to the Cloud Platform Manager, tracked through quarterly risk reviews.

---

Q30.

What is an IS governance audit?

**Answer:** An independent examination of the IS governance structure, policies, and processes to assess alignment with business objectives and compliance with frameworks.

*Example:* An external auditor reviews the board's IS oversight activities and finds the board lacks quarterly IS briefings required by the IS governance policy.

---

Q31.

What is executive sponsorship in IS Governance?

**Answer:** Support from senior leadership (CEO, board) that provides authority, resources, and visibility to the IS program, ensuring organization-wide commitment.

*Example:* The CEO publicly champions the new IS awareness program and includes IS responsibility in all senior managers' performance objectives.

---

## Domain 2: Information Risk Management (20%)

Q32.

What is Information Risk Management?

**Answer:** The process of identifying, analyzing, evaluating, treating, and monitoring risks to information assets to keep residual risk within acceptable levels.

*Example:* A bank identifies ransomware as a top risk, assesses its likelihood and impact, and implements backup, EDR, and IR controls as treatment.

---

Q33.

What are the steps in the risk management process?

**Answer:** 1. Asset identification, 2. Threat identification, 3. Vulnerability identification, 4. Risk assessment, 5. Risk treatment, 6. Monitoring and review.

*Example:* Step 3 example: A vulnerability scan reveals 50 unpatched servers exposed to a known exploit (CVE-2024-XXXX).

---

Q34.

What is a threat?

**Answer:** Any potential event or action that could exploit a vulnerability and cause harm to information assets.



*Example:* Phishing emails targeting finance employees are a threat that could lead to credential theft and unauthorized wire transfers.

---

Q35.

What is a vulnerability?

**Answer:** A weakness in a system, process, or control that can be exploited by a threat to cause harm.

*Example:* An unpatched Apache web server running a vulnerable version is a vulnerability that could be exploited by a remote attacker.

---

Q36.

What is risk?

**Answer:** The combination of the likelihood that a threat will exploit a vulnerability and the impact it would have on the organization.

*Example:* Risk = Likelihood (High) × Impact (High) □ a critical risk requiring immediate treatment, such as a publicly exposed RDP service.

---

Q37.

What is residual risk?

**Answer:** The risk that remains after security controls have been applied; it should be within the organization's defined risk appetite.

*Example:* After implementing MFA and privileged access management, the residual risk of credential-based attacks drops from High to Low.

---

Q38.

What is inherent risk?

**Answer:** The level of risk that exists before any controls are applied; the natural risk level of a process or environment.

*Example:* A cloud-hosted customer database has a high inherent risk of data exposure before encryption and access controls are implemented.

---

Q39.

What is a Risk Register?

**Answer:** A document that records identified risks, their assessment scores, owners, treatment decisions, and status used to track and manage risks over time.

*Example:* The IS risk register lists 'Third-party vendor breach' as Risk #12 with a High rating, assigned to the Vendor Manager, with quarterly review dates.

---

Q40.

What are the four risk treatment options?

**Answer:** 1. Accept: tolerate the risk. 2. Avoid: eliminate the risk by stopping the activity. 3. Transfer: shift risk to a third party (e.g., insurance). 4. Mitigate: apply controls to reduce likelihood or impact.

*Example:* A small company accepts the risk of not having a DLP tool due to cost, documents the acceptance, and reviews it annually.

---

Q41.

What is risk acceptance and when is it appropriate?

**Answer:** Formally acknowledging and accepting a risk when the cost of treatment exceeds the potential loss and it falls within the risk appetite.

*Example:* Management formally accepts the risk of using an end-of-life internal tool for 6 more months while a replacement is procured.

---

Q42.

What is a Business Impact Analysis (BIA)?

**Answer:** A process to identify critical business functions, assess the impact of disruptions, and determine Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO).

*Example:* BIA for a payment processing system: RTO = 4 hours, RPO = 1 hour. Any downtime beyond this triggers the DR plan.

---

Q43.

What is quantitative risk analysis?

**Answer:** Risk analysis using numerical values (monetary amounts, probabilities) to calculate risk exposure and support financial decision-making.

*Example:*  $ALE = SLE \times ARO$ . If a breach costs \$500K (SLE) and occurs 0.3 times per year (ARO),  $ALE = \$150K$ , justifying \$100K annual security investment.

---

Q44.

What is qualitative risk analysis?

**Answer:** Risk analysis using descriptive scales (High/Medium/Low) based on expert judgment and relative scoring rather than precise numerical values.

*Example:* A 5x5 risk matrix rates a ransomware threat as Likelihood=High, Impact=Critical, giving an overall risk rating of Critical.

---

Q45.

What is Single Loss Expectancy (SLE)?

**Answer:** The monetary loss expected from a single occurrence of a risk event.

*Example:* A data breach exposing 10,000 records at \$150/record notification cost gives  $SLE = \$1.5M$ .

---

Q46.

What is Annualized Loss Expectancy (ALE)?

**Answer:** The expected annual financial loss from a risk, calculated as  $ALE = SLE \times ARO$  (Annualized Rate of Occurrence).

*Example:* If a server failure (SLE \$200K) occurs twice per year (ARO=2),  $ALE = \$400K$ , helping justify a \$150K HA solution.

---

Q47.

What is a risk assessment?

**Answer:** A systematic process of identifying, analyzing, and evaluating risks to determine their significance and prioritize treatment actions.

*Example:* An annual IS risk assessment identifies cloud misconfiguration as the top risk after reviewing recent security incidents and threat intelligence.

---

Q48.

What is threat modeling?

**Answer:** A structured approach to identifying and prioritizing potential threats to a system or application and designing countermeasures.

*Example:* Using STRIDE, a development team models threats to a new payment API: Spoofing, Tampering, Repudiation, Info Disclosure, DoS, Elevation of Privilege.

---

Q49.

What is STRIDE in threat modeling?

**Answer:** A framework categorizing threats as: Spoofing identity, Tampering with data, Repudiation, Information disclosure, Denial of service, Elevation of privilege.

*Example:* For a web login form: Spoofing (fake credentials), Tampering (SQL injection), Repudiation (no audit logs), Info Disclosure (verbose errors).

---

Q50.

What is DREAD in risk scoring?

**Answer:** A risk scoring model: Damage potential, Reproducibility, Exploitability, Affected users, Discoverability — each scored 1–10 to prioritize threats.

*Example:* A web app SQL injection: Damage=9, Reproducibility=9, Exploitability=8, Affected=10, Discoverability=7 □ Total 43/50 □ Critical priority.

---

Q51.

What is a vulnerability assessment?

**Answer:** A systematic review of systems and networks to identify, quantify, and prioritize security weaknesses using automated tools and manual analysis.

*Example:* Nessus scans identify 120 vulnerabilities; 15 critical ones (CVSS  $\geq 9.0$ ) are prioritized for patching within 24 hours.

---

Q52.

What is a penetration test?

**Answer:** An authorized simulated cyberattack on a system to identify exploitable vulnerabilities and test the effectiveness of security controls.

*Example:* A red team pen test exploits a misconfigured S3 bucket to access 50,000 customer records, prompting immediate remediation.

---

Q53.

What is the difference between a vulnerability assessment and a penetration test?

**Answer:** Vulnerability assessment: identifies and lists weaknesses. Penetration test: actively exploits weaknesses to demonstrate real-world attack impact.

*Example:* VA: 'Port 3389 is open and unpatched.' Pen test: 'We exploited CVE-2019-0708 on port 3389 and gained SYSTEM access to the domain controller.'

---

Q54.

What is a risk treatment plan?

**Answer:** A documented plan that describes how identified risks will be addressed, including control selection, timelines, resource allocation, and risk owners.

*Example:* Risk treatment plan item: 'Implement PAM solution by Q3 to mitigate privileged account misuse risk (Owner: IT Security Manager, Budget: \$80K).'

---

Q55.

What is the risk management lifecycle?

**Answer:** A continuous process: 1. Context establishment, 2. Risk identification, 3. Risk analysis, 4. Risk evaluation, 5. Risk treatment, 6. Communication, 7. Monitoring and review.

*Example:* After a near-miss ransomware incident, the organization re-enters the lifecycle at step 2 to re-evaluate its backup and EDR risks.

---

Q56.

What is a risk scenario?

**Answer:** A narrative describing a plausible threat event, its path of exploitation, and potential business impact used to assess risk in context.

*Example:* Scenario: 'A phishing email tricks an employee into providing VPN credentials; attacker moves laterally and exfiltrates HR salary data.'

---

Q57.

What is third-party risk management?

**Answer:** Identifying, assessing, and managing risks posed by vendors, suppliers, and partners who have access to the organization's systems or data.

*Example:* Before onboarding a SaaS payroll provider, the security team conducts a vendor risk assessment reviewing SOC 2 Type II report and data handling agreements.

---

Q58.

What is a risk matrix?

**Answer:** A visual tool plotting risks by likelihood vs. impact to prioritize treatment decisions.

*Example:* A 5×5 risk matrix shows 'cloud data leak' at Likelihood=4, Impact=5, placing it in the top-right 'Critical' zone requiring immediate action.

---

Q59.

What is information asset classification?

**Answer:** The process of categorizing information assets based on their sensitivity and criticality to apply appropriate security controls.

*Example:* Data classification levels: Public, Internal, Confidential, Restricted. Customer PII is classified as Restricted, requiring encryption and strict access controls.

---

Q60.

What is a control?

**Answer:** A safeguard or countermeasure implemented to reduce the likelihood or impact of a risk.

*Example:* MFA is a control that reduces the risk of credential-based account takeover by requiring a second authentication factor.

---

Q61.

What is the difference between preventive, detective, and corrective controls?

**Answer:** Preventive: stop incidents from occurring. Detective: identify incidents after they occur. Corrective: restore normal operations after an incident.

*Example:* Preventive: firewall rules. Detective: IDS/SIEM alerts. Corrective: restoring from backup after ransomware encryption.

---

## Domain 3: Information Security Program (33%)

Q62.

What is an Information Security Program?

**Answer:** A comprehensive set of policies, procedures, controls, and activities designed to protect information assets, manage risks, and achieve security objectives aligned with business goals.

*Example:* An IS program at a healthcare company includes HIPAA controls, security awareness training, incident response, and quarterly risk assessments.

---

Q63.

What are the key components of an IS Program?

**Answer:** Governance framework, risk management, security policies, asset management, access control, security awareness, incident response, BCP/DRP, compliance management, and performance monitoring.

*Example:* A financial institution's IS program includes all components, with PCI DSS compliance as a key driver for program design.

---

Q64.

What is security architecture?

**Answer:** A unified security design that addresses the requirements and potential risks involved in a certain scenario or environment and how security controls are structured to protect information assets.

*Example:* An enterprise adopts a Zero Trust security architecture, implementing microsegmentation, continuous authentication, and least-privilege access across all systems.

---

Q65.

What is defense in depth?

**Answer:** A layered security strategy that uses multiple security controls so that if one layer fails, others still protect the asset.

*Example:* Attacker bypasses firewall (layer 1) but is stopped by network IDS (layer 2), then EDR (layer 3), preventing data exfiltration.

---

Q66.

What is a security baseline?

**Answer:** A minimum set of security controls required for all systems in the organization, providing a consistent security foundation.

*Example:* CIS Benchmarks are used as the security baseline for all Windows servers: disable unused services, enable audit logging, enforce password complexity.

---

Q67.

What is configuration management in IS?

**Answer:** The process of maintaining and tracking the configuration of IT assets to ensure they conform to approved baselines and changes are controlled.

*Example:* A CMDB tracks all server configurations; any deviation from the approved hardening baseline triggers an automatic alert to the security team.

---

Q68.

What is change management in IS context?

**Answer:** A formal process for requesting, reviewing, approving, implementing, and documenting changes to IT systems to prevent unauthorized or disruptive changes.

*Example:* A change to the core banking firewall rules requires approval from the Change Advisory Board (CAB) before implementation.

---

Q69.

What is patch management?

**Answer:** The process of identifying, acquiring, testing, and deploying software patches to fix vulnerabilities and maintain system security.

*Example:* A patch management policy requires critical patches (CVSS  $\geq 9.0$ ) to be deployed within 24 hours of release, validated in a staging environment first.

---

Q70.

What is access control?

**Answer:** Mechanisms that restrict access to systems, data, and resources to authorized users and processes only.

*Example:* Role-based access control (RBAC) ensures HR employees can access employee records but not financial systems.

---

Q71.

What are the types of access control?

**Answer:** Mandatory Access Control (MAC): system-enforced based on classifications.

Discretionary Access Control (DAC): owner-controlled. Role-Based (RBAC): based on job roles. Attribute-Based (ABAC): based on multiple attributes.

*Example:* Government classified systems use MAC (e.g., Top Secret/Secret/Unclassified labels). Corporate systems typically use RBAC.

---

Q72.

What is Identity and Access Management (IAM)?

**Answer:** A framework for managing digital identities and controlling user access to resources, including authentication, authorization, and provisioning/deprovisioning.

*Example:* IAM system automatically disables a user account within 4 hours of HR submitting a termination request in the ITSM system.

---

Q73.

What is Multi-Factor Authentication (MFA)?

**Answer:** An authentication method requiring users to provide two or more verification factors: something you know, something you have, or something you are.

*Example:* VPN access requires a password (know) + hardware token OTP (have), preventing attackers from using stolen credentials alone.

---

Q74.

What is Single Sign-On (SSO)?

**Answer:** An authentication process allowing users to access multiple applications with a single set of credentials after one authentication event.



*Example:* Employees log in once to the corporate SSO portal (via SAML) and gain access to Salesforce, Office 365, and ServiceNow without re-authenticating.

---

Q75.

What is privileged access management (PAM)?

**Answer:** Controls and tools for managing, monitoring, and auditing privileged accounts (admin, root, service accounts) to prevent misuse.

*Example:* PAM solution requires IT admins to check out time-limited admin credentials from a vault, with all sessions recorded for audit.

---

Q76.

What is encryption and when should it be used?

**Answer:** Encryption transforms data into an unreadable format using algorithms and keys to protect confidentiality. Use at rest, in transit, and for sensitive backups.

*Example:* Customer credit card data is encrypted at rest using AES-256 in the database and in transit using TLS 1.3 between browser and server.

---

Q77.

What is PKI (Public Key Infrastructure)?

**Answer:** A system of digital certificates, certificate authorities, and cryptographic keys that enables secure electronic communications and digital signatures.

*Example:* A company deploys PKI to issue SSL/TLS certificates for its web servers and S/MIME certificates for secure executive email communication.

---

Q78.

What is a digital certificate?

**Answer:** An electronic document issued by a Certificate Authority (CA) that binds a public key to an entity's identity and is used to verify authenticity.

*Example:* A web server's SSL certificate issued by DigiCert proves the domain belongs to the legitimate organization to website visitors.

---

Q79.

What is data loss prevention (DLP)?

**Answer:** Technology and policies that detect and prevent unauthorized transmission, sharing, or storage of sensitive data.

*Example:* DLP software blocks an employee from emailing a spreadsheet containing 500 customer Social Security Numbers to a personal Gmail account.

---

Q80.

What is a SIEM (Security Information and Event Management)?



**Answer:** A system that aggregates, correlates, and analyzes log data from across the IT environment to detect security incidents and support compliance reporting.

*Example:* SIEM correlates 5 failed logins followed by a successful login from an unusual country and triggers an alert to the SOC team.

---

Q81.

What is security monitoring?

**Answer:** Continuous collection and analysis of security data to detect threats, anomalies, and policy violations in real time.

*Example:* 24/7 SOC monitors SIEM alerts, firewall logs, and EDR telemetry to detect and respond to threats within a 1-hour SLA.

---

Q82.

What is network security?

**Answer:** Controls that protect the confidentiality, integrity, and availability of data in transit across networks.

*Example:* Network security controls include firewalls, IDS/IPS, network segmentation, VPN, and TLS encryption for all web traffic.

---

Q83.

What is endpoint security?

**Answer:** Protecting end-user devices (laptops, mobiles, workstations) from threats using controls like EDR, AV, disk encryption, and patch management.

*Example:* All company laptops have EDR, BitLocker encryption, and are enrolled in MDM for remote wipe capability if lost or stolen.

---

Q84.

What is cloud security?

**Answer:** Security practices, controls, and technologies protecting cloud-hosted data, applications, and infrastructure from threats and misconfigurations.

*Example:* A cloud security posture management (CSPM) tool continuously scans AWS environments for misconfigurations like public S3 buckets or open security groups.

---

Q85.

What is a security awareness training program?

**Answer:** Formal education designed to build employees' knowledge of security risks, policies, and safe behaviors to reduce human error as a threat vector.

*Example:* After phishing simulation, employees who click the fake link are automatically enrolled in a 15-minute phishing awareness module.

---

Q86.

What is a security assessment?

**Answer:** A formal evaluation of security controls, policies, and processes to determine effectiveness and identify gaps requiring remediation.

*Example:* Annual NIST CSF security assessment reveals gaps in the Respond and Recover functions, driving a 6-month remediation roadmap.

---

Q87.

What is a data classification scheme?

**Answer:** A tiered system for categorizing data by sensitivity to apply appropriate protection controls at each level.

*Example:* Classification tiers: Public □ Internal Use Only □ Confidential □ Top Secret. Each tier has specific handling, storage, and transmission requirements.

---

Q88.

What is secure software development?

**Answer:** Integrating security practices throughout the software development lifecycle (SDLC) to prevent vulnerabilities from being built into applications.

*Example:* Developers use OWASP Top 10 as a checklist during code review, and SAST tools automatically scan code for SQL injection and XSS flaws in the CI/CD pipeline.

---

Q89.

What is the OWASP Top 10?

**Answer:** OWASP's list of the ten most critical web application security risks including injection, broken authentication, sensitive data exposure, and others.

*Example:* A developer fixes an SQL injection vulnerability (OWASP #1) by replacing dynamic SQL queries with parameterized queries in the login function.

---

Q90.

What is a security roadmap?

**Answer:** A prioritized plan of security initiatives, timelines, and investments aligned to risk reduction goals and the IS strategy.

*Example:* The IS security roadmap for 2025–2027 prioritizes: Year 1 – Zero Trust implementation; Year 2 – SOC maturity; Year 3 – AI-powered threat detection.

---

Q91.

What is IS program performance measurement?

**Answer:** Tracking KPIs and KRIs to demonstrate the IS program's effectiveness, maturity, and alignment with business objectives.

*Example:* Monthly IS dashboard shows: 98% patch compliance, 0.8% phishing click rate, 4-hour mean MTTR, 100% security awareness training completion.

---

Q92.

What is a control framework?

**Answer:** A structured set of security controls that can be selected and implemented to manage risks (e.g., ISO 27001, NIST SP 800-53, CIS Controls).

*Example:* An organization maps its existing controls to NIST SP 800-53 to identify control gaps before a FedRAMP authorization process.

---

Q93.

What is ISO/IEC 27001?

**Answer:** An international standard specifying requirements for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS).

*Example:* A company achieves ISO 27001 certification after implementing 114 controls from Annex A and passing a third-party audit.

---

Q94.

What is NIST Cybersecurity Framework (CSF)?

**Answer:** A voluntary framework with five core functions — Identify, Protect, Detect, Respond, Recover — providing guidelines for managing cybersecurity risk.

*Example:* An organization uses NIST CSF to assess its cybersecurity posture, discovering gaps in the Detect and Respond functions.

---

## Domain 4: Incident Management (30%)

Q95.

What is an Information Security Incident?

**Answer:** An event that actually or potentially compromises the confidentiality, integrity, or availability of information assets or constitutes a violation of security policies.

*Example:* A ransomware attack encrypting 500 servers is a major IS incident requiring immediate activation of the incident response plan.

---

Q96.

What is Incident Management?

**Answer:** The processes and procedures for detecting, reporting, assessing, responding to, and recovering from information security incidents.

*Example:* An organization's incident management process handles 200+ security events monthly, escalating 12 to full incident response investigations.

---

Q97.

What are the phases of Incident Response (IR)?

**Answer:** 1. Preparation, 2. Identification/Detection, 3. Containment, 4. Eradication, 5. Recovery, 6. Post-Incident Review (Lessons Learned).

*Example:* During a breach: Detection (SIEM alert) □ Containment (isolate affected server) □ Eradication (remove malware) □ Recovery (restore from backup) □ PIR (update controls).

---

Q98.

What is an Incident Response Plan (IRP)?

**Answer:** A documented plan defining the processes, roles, responsibilities, and procedures for responding to security incidents.

*Example:* The IRP is activated when a data breach is detected, assigning roles to the IR team, legal, PR, and executive sponsors.

---

Q99.

What is the Incident Response Team (IRT)?

**Answer:** A cross-functional team responsible for executing the incident response plan, including security, IT, legal, HR, communications, and management representatives.

*Example:* The IRT for a healthcare breach includes: IR Lead, Forensics Analyst, Legal Counsel, HIPAA Privacy Officer, and Communications Director.

---

Q100.

What is containment in incident response?

**Answer:** Actions taken to limit the scope and impact of an incident by isolating affected systems, blocking malicious traffic, or restricting attacker access.

*Example:* During a ransomware incident, the IR team isolates 20 infected servers from the network within 15 minutes to prevent further encryption.

---

Q101.

What is eradication in incident response?

**Answer:** Removing the root cause of the incident — malware, backdoors, compromised accounts, or vulnerabilities — after containment.

*Example:* Eradication steps: remove ransomware payload, delete malicious scheduled tasks, reset all compromised credentials, and patch the exploited vulnerability.

---

Q102.

What is forensic investigation?

**Answer:** The systematic collection, preservation, and analysis of digital evidence to understand how an incident occurred and support legal or disciplinary action.

*Example:* Forensic analysts create bit-for-bit disk images of compromised servers before remediation to preserve evidence for potential legal proceedings.

---

Q103.

What is chain of custody in digital forensics?

**Answer:** A documented trail proving the integrity of digital evidence from collection through analysis, ensuring it hasn't been tampered with.

*Example:* Each forensic artifact is tagged with collection time, collector name, hash value, and storage location – documented in the evidence log.

---

Q104.

What is the difference between an event, alert, and incident?

**Answer:** Event: any observable occurrence in a system. Alert: an event flagged as potentially significant. Incident: a confirmed event causing or risking harm to information assets.

*Example:* Event: 10,000 login attempts logged. Alert: SIEM flags >100 failed logins from one IP. Incident: confirmed brute force attack with 3 successful logins.

---

Q105.

What is triage in incident response?

**Answer:** The process of quickly assessing and prioritizing incidents by severity to allocate response resources most effectively.

*Example:* IR triage classifies a data exfiltration alert as P1-Critical, a failed phishing attempt as P3-Low, allocating immediate resources to P1.

---

Q106.

What is a playbook in incident response?

**Answer:** A predefined, step-by-step set of procedures for responding to specific types of incidents (e.g., ransomware, phishing, data breach).

*Example:* The ransomware playbook guides the IR team through: detection confirmation, executive notification, network isolation, law enforcement contact, and recovery steps.

---

Q107.

What is Business Continuity Planning (BCP)?

**Answer:** The process of creating systems of prevention and recovery to deal with potential threats to a company, ensuring continuity of critical business functions.

*Example:* A BCP ensures the call center can operate from a backup facility within 4 hours if the primary data center suffers a flood.

---

Q108.

What is Disaster Recovery Planning (DRP)?

**Answer:** A set of procedures for recovering IT systems, data, and infrastructure after a disaster to restore normal operations within defined RTOs.

*Example:* The DRP specifies that the core banking system must be restored to a DR site within 4 hours (RTO) with data loss not exceeding 1 hour (RPO).

---

Q109.

What is Recovery Time Objective (RTO)?

**Answer:** The maximum acceptable time to restore a system or process after a disruption.

*Example:* The e-commerce platform's RTO is 2 hours — any outage beyond this causes unacceptable revenue loss and triggers DR plan activation.

---

Q110.

What is Recovery Point Objective (RPO)?

**Answer:** The maximum acceptable amount of data loss measured in time — how far back data can be restored from backups.

*Example:* Banking system RPO = 15 minutes; continuous replication ensures no more than 15 minutes of transactions are lost in a DR event.

---

Q111.

What is a tabletop exercise?

**Answer:** A discussion-based simulation where team members walk through a hypothetical incident scenario to test plans, identify gaps, and improve response procedures.

*Example:* The IRT conducts a ransomware tabletop exercise, discovering that the legal escalation path was unclear and the DPO role was not included in communications.

---

Q112.

What is a full-scale exercise?

**Answer:** A live simulation of a disaster or incident that tests the actual execution of recovery plans, involving real systems and personnel.

*Example:* A full-scale DR exercise fails over the payment system to the DR site, discovering replication lag caused 2-hour data loss instead of the target 15 minutes.

---

Q113.

What is a hot site?

**Answer:** A fully equipped, operational backup facility that can take over operations almost immediately (minutes to hours) after a primary site failure.

*Example:* A financial firm maintains a hot site 50km from its primary data center with real-time data replication, enabling 30-minute failover for trading systems.

---

Q114.

What is a warm site?

**Answer:** A backup facility partially equipped with hardware and infrastructure that can be operational within hours to days after configuration.

*Example:* A warm site has servers and network gear pre-installed but requires data restoration from backups — achievable within 8-12 hours.

---

Q115.

What is a cold site?

**Answer:** A backup facility with basic infrastructure (power, cooling, space) but no pre-installed equipment, requiring days to weeks to become operational.

*Example:* A cold site is cost-effective for non-critical systems where a 1-2 week recovery time is acceptable per the BIA.

---

Q116.

What is a CSIRT (Computer Security Incident Response Team)?

**Answer:** A dedicated team responsible for coordinating and executing the organization's response to cybersecurity incidents.

*Example:* The CSIRT handles the full incident lifecycle: detection, analysis, containment, eradication, recovery, and reporting to management.

---

Q117.

What is mandatory breach notification?

**Answer:** Legal requirements obligating organizations to notify affected individuals, regulators, or authorities when a data breach occurs within defined timeframes.

*Example:* Under GDPR, organizations must notify the supervisory authority within 72 hours of discovering a personal data breach involving EU residents.

---

Q118.

What is the purpose of a post-incident review (PIR)?

**Answer:** To analyze the incident after resolution: understand root causes, assess response effectiveness, identify lessons learned, and improve controls and processes.

*Example:* PIR after a breach reveals the attacker persisted for 45 days undetected – leading to deployment of a user behavior analytics (UBA) tool.

---

Q119.

What is root cause analysis (RCA) in incident management?

**Answer:** A method for identifying the fundamental reason an incident occurred, going beyond symptoms to prevent recurrence.

*Example:* RCA of a SQL injection breach: root cause was developers not trained on secure coding – leading to mandatory OWASP training for all developers.

---

Q120.

What are indicators of compromise (IoCs)?

**Answer:** Artifacts or evidence that suggest a system has been breached or attacked, such as malicious IPs, file hashes, domain names, or registry keys.

*Example:* IoCs from a breach investigation: C2 domain 'malware-c2.ru', malicious file hash SHA256:abc123..., and suspicious registry key 'HKCU\Software\Updater'.



---

Q121.

What is the kill chain model?

**Answer:** Lockheed Martin's framework describing the stages of a cyberattack: Reconnaissance, Weaponization, Delivery, Exploitation, Installation, C2, and Actions on Objectives.

*Example:* Defenders block the kill chain at Delivery stage by quarantining a phishing email before the user can click the malicious link.

---

Q122.

What is MITRE ATT&CK;?

**Answer:** A globally accessible knowledge base of adversary tactics, techniques, and procedures (TTPs) based on real-world observations, used for threat detection and defense.

*Example:* SOC analysts map a detected attack to MITRE ATT&CK; technique T1566.001 (Spearphishing Attachment) to improve detection rules.

---

Q123.

What is evidence handling in incident response?

**Answer:** The proper collection, preservation, documentation, and analysis of digital evidence following forensic principles to maintain integrity.

*Example:* All logs, disk images, and memory captures are stored in a write-protected evidence drive with SHA-256 hashes recorded before and after collection.

---

Q124.

What is crisis communication in incident management?

**Answer:** The process of communicating accurate, timely information to stakeholders (employees, customers, regulators, media) during and after a security incident.

*Example:* During a breach, the PR team releases a public statement within 24 hours acknowledging the incident and outlining steps taken, while legal reviews all external communications.

---

Q125.

What is the role of law enforcement in incident response?

**Answer:** Law enforcement may be engaged for incidents involving criminal activity (ransomware, espionage), providing investigative resources and legal authority.

*Example:* A company contacts the FBI Cyber Division after a ransomware attack attributed to a nation-state group, sharing IoCs under legal counsel's guidance.

---

Q126.

What is a security incident classification scheme?

**Answer:** A predefined taxonomy for categorizing incidents by type (malware, unauthorized access, data breach) and severity (P1-P4) to guide response prioritization.

*Example:* Classification: P1-Critical (active breach with data loss), P2-High (ransomware contained), P3-Medium (phishing attempt), P4-Low (policy violation).

---

Q127.

What is mean time to detect (MTTD) and mean time to respond (MTTR)?

**Answer:** MTTD: average time from incident occurrence to detection. MTTR: average time from detection to full resolution. Both are key IR performance metrics.

*Example:* Industry benchmark: MTTD = 197 days, MTTR = 69 days. Organization target: MTTD < 24 hours and MTTR < 8 hours using SIEM + SOC automation.

---

## Domain 1: Additional Governance Questions

Q128.

What is an information security policy framework?

**Answer:** A hierarchical set of documents — policies, standards, procedures, and guidelines — that collectively define and govern the organization's IS requirements.

*Example:* A policy framework has a top-level IS Policy, supported by 12 topic-specific standards (e.g., Password Standard, Encryption Standard) and 30+ procedures.

---

Q129.

What is the role of the General Counsel in IS Governance?

**Answer:** Advises on legal obligations, data protection laws, contractual security requirements, and manages legal risk related to IS incidents.

*Example:* General Counsel reviews vendor DPA for GDPR compliance before the CISO approves a new EU customer data processor.

---

Q130.

What is the principle of accountability in governance?

**Answer:** Individuals and entities must be answerable for their security roles and decisions, with clear assignment of responsibility and audit trails.

*Example:* The cloud architect is accountable for ensuring all cloud resources comply with the encryption standard, verified quarterly by internal audit.

---

Q131.

What is a governance, risk, and compliance (GRC) tool?

**Answer:** An integrated platform for managing governance policies, risk assessments, compliance requirements, and audit workflows in one system.

*Example:* An organization deploys ServiceNow GRC to automate PCI DSS control assessments, evidence collection, and risk register updates.

---

Q132.

How does IS governance support digital transformation?

**Answer:** By ensuring new digital initiatives (cloud, AI, IoT) are assessed for risk, governed by appropriate policies, and aligned with the security architecture.

*Example: Before launching an AI-powered customer service bot, IS governance requires a privacy impact assessment and data classification review.*

---

Q133.

What is an IS governance gap analysis?

**Answer:** A comparison of the current IS governance state against a desired framework or standard to identify deficiencies requiring remediation.

*Example: A gap analysis against ISO 27001 reveals 30 controls partially or not implemented, forming the basis of a 12-month improvement roadmap.*

---

Q134.

What is tone at the top in IS governance?

**Answer:** The attitude and commitment demonstrated by senior leadership toward IS, which cascades throughout the organization and drives security culture.

*Example: The CEO includes IS objectives in all executive KPIs and personally sponsors the annual security awareness campaign.*

---

Q135.

What is a security operations center (SOC)?

**Answer:** A centralized facility where security analysts monitor, detect, investigate, and respond to cybersecurity threats on a 24/7 basis.

*Example: The SOC team uses SIEM, SOAR, and threat intelligence to investigate 1,000 daily alerts, escalating 15 to full IR investigations.*

---

Q136.

What is the concept of information lifecycle management?

**Answer:** Managing information from creation through use, storage, archival, and secure disposal in accordance with classification and legal requirements.

*Example: Financial records are retained for 7 years per regulation, then securely destroyed using DoD 5220.22-M standard or physical shredding.*

---

Q137.

What is a security metrics program?

**Answer:** A systematic approach to collecting, analyzing, and reporting IS performance data to support governance decisions.

*Example: Monthly security metrics: patch rate 97%, phishing click rate 1.2%, vulnerability mean age 8.5 days, and 0 P1 incidents this month.*

---

## Domain 2: Additional Risk Questions

Q138.

What is a risk taxonomy?

**Answer:** A structured classification of risks into categories (strategic, operational, compliance, reputational) to ensure comprehensive risk identification.

*Example:* IS risk taxonomy categories: Cyber threats, Data privacy, Third-party, Technology, Compliance, Physical security – used to structure the risk register.

---

Q139.

What is scenario-based risk analysis?

**Answer:** Using specific, detailed threat scenarios to evaluate risks and test control effectiveness in realistic contexts.

*Example:* Scenario: 'Nation-state actor uses zero-day exploit against VPN appliance to gain persistent network access for 6 months.' Controls tested: patch management, segmentation, detection.

---

Q140.

What is emerging risk?

**Answer:** A risk that is newly identified or whose significance is increasing due to changes in technology, regulation, or threat landscape.

*Example:* AI-generated deepfake voice phishing targeting CFOs for wire fraud is an emerging risk requiring updates to financial authorization controls.

---

Q141.

What is a risk register review?

**Answer:** A periodic process of revisiting recorded risks to update likelihood/impact scores, verify treatment effectiveness, and add new risks.

*Example:* Quarterly risk register review elevates 'supply chain software compromise' from Medium to High risk following SolarWinds-type incidents in the industry.

---

Q142.

What is the role of threat intelligence in risk management?

**Answer:** Providing current, relevant information about adversaries, TTPs, and vulnerabilities to improve risk assessments and defensive decision-making.

*Example:* Threat intel feed identifies that a ransomware group is actively targeting healthcare organizations; the CISO prioritizes EDR upgrades based on this intelligence.

---

Q143.

What is a supply chain risk?

**Answer:** Risks arising from vulnerabilities or threats within the organization's supply chain – hardware, software, or service providers.

*Example:* A malicious update pushed by a compromised software vendor (like SolarWinds) can introduce backdoors into thousands of customer environments.

---

Q144.

What is a risk heat map?

**Answer:** A visual representation of the risk landscape showing multiple risks plotted by likelihood and impact to facilitate prioritization.

*Example:* The risk heat map shows 3 risks in the 'Red Zone' (High/High): ransomware, API data exposure, and third-party breach – all requiring immediate treatment.

---

Q145.

What is operational risk?

**Answer:** Risk of loss resulting from inadequate or failed internal processes, people, systems, or from external events.

*Example:* An operator accidentally deletes a production database without a tested backup – an operational risk event causing significant business disruption.

---

Q146.

What is a risk owner?

**Answer:** An individual who is accountable for ensuring an identified risk is properly assessed, treated, and monitored.

*Example:* The VP of Engineering is the risk owner for 'unpatched application vulnerabilities,' responsible for ensuring remediation within policy SLAs.

---

Q147.

What is risk communication?

**Answer:** The process of sharing risk information with stakeholders in a clear, actionable, and appropriately detailed format.

*Example:* The CISO translates technical risks into business language for the board: 'A ransomware attack could disrupt operations for 2 weeks, costing \$5M in lost revenue.'

---

## Domain 3: Additional IS Program Questions

Q148.

What is a security operations maturity model?

**Answer:** A framework for assessing and advancing the maturity of security operations capabilities from reactive (Level 1) to proactive and optimized (Level 5).

*Example:* An organization at SOC maturity Level 2 develops a roadmap to reach Level 4 by implementing SOAR, threat hunting, and metrics-driven operations.

---

Q149.

What is threat hunting?

**Answer:** Proactively searching through networks and systems for advanced threats that evade automated security tools.

*Example:* A threat hunter discovers lateral movement artifacts in EDR telemetry matching a known APT group's TTP, 3 weeks before an automated alert would have triggered.

---

Q150.

What is SOAR (Security Orchestration, Automation, and Response)?

**Answer:** Technology that automates repetitive security tasks, orchestrates tools, and streamlines incident response workflows.

*Example:* SOAR automatically enriches phishing alerts with threat intel, quarantines malicious emails, and blocks attacker IPs in the firewall — all within 90 seconds.

---

Q151.

What is zero trust architecture?

**Answer:** A security model based on 'never trust, always verify' — requiring continuous authentication and least-privilege access regardless of network location.

*Example:* Zero trust implementation: all users (internal and remote) authenticate via MFA, devices are verified via posture checks, and access is segmented by role.

---

Q152.

What is a vulnerability management program?

**Answer:** A continuous process of identifying, classifying, prioritizing, remediating, and reporting on security vulnerabilities across the IT environment.

*Example:* Vulnerability management SLA: Critical (CVSS 9.0+) patched in 24h, High (7.0-8.9) in 7 days, Medium in 30 days, Low in 90 days.

---

Q153.

What is a red team vs. blue team exercise?

**Answer:** Red team: offensive security team simulating real attackers. Blue team: defensive team detecting and responding. Purple team: combined exercise with knowledge sharing.

*Example:* Red team gains domain admin via phishing; blue team detects the lateral movement via SIEM after 6 hours — post-exercise, detection rules are improved.

---

Q154.

What is application security (AppSec)?

**Answer:** The practice of protecting applications from security threats through secure design, development, testing, and deployment practices.

*Example:* AppSec program includes: SAST in CI/CD pipeline, DAST scanning before release, dependency scanning for CVEs, and developer security training.

---

Q155.

What is a Bug Bounty Program?

**Answer:** An initiative inviting external security researchers to find and responsibly disclose vulnerabilities in exchange for monetary rewards.

*Example:* A tech company's bug bounty program pays \$10K for critical vulnerabilities; researchers discover 5 critical API flaws before attackers do.

---

Q156.

What is DevSecOps?

**Answer:** The integration of security practices into the DevOps pipeline, ensuring security is addressed continuously throughout development and operations.

*Example:* DevSecOps pipeline: code commit → SAST scan → dependency check → container image scan → security gate → deploy (with DAST post-deploy).

---

Q157.

What is network segmentation?

**Answer:** Dividing a network into isolated segments or zones to limit lateral movement of threats and reduce the blast radius of a breach.

*Example:* PCI DSS requires the cardholder data environment (CDE) to be segmented from the rest of the corporate network using firewalls and VLANs.

---

Q158.

What is microsegmentation?

**Answer:** Granular network segmentation at the workload or application level, enforcing least-privilege traffic flows between individual services.

*Example:* Microsegmentation prevents an attacker who compromised a web server from reaching the database server – only specific app-tier traffic is allowed.

---

Q159.

What is an insider threat?

**Answer:** A security risk originating from current or former employees, contractors, or partners who misuse authorized access.

*Example:* A departing sales employee exfiltrates the customer database to a personal USB drive – an insider threat caught by DLP monitoring.

---

Q160.



What is user behavior analytics (UBA)?

**Answer:** Machine learning-based technology that analyzes patterns of user behavior to detect anomalies indicating insider threats or compromised accounts.

*Example:* UBA flags a finance employee accessing 1,000 records at 2 AM (100× their baseline) – investigation reveals compromised credentials.

---

Q161.

What is a security program roadmap?

**Answer:** A prioritized, time-phased plan of IS initiatives that improves security posture and aligns with the IS strategy and risk treatment plans.

*Example:* Roadmap: Q1 - Deploy PAM; Q2 - Implement Zero Trust network; Q3 - Launch security awareness reboot; Q4 - Achieve ISO 27001 certification.

---

Q162.

What is data governance?

**Answer:** The overall management of data availability, usability, integrity, and security in an enterprise, including data ownership, classification, and lifecycle management.

*Example:* Data governance policy defines that all PII must be discovered, classified, minimized, and protected under the Chief Data Officer's oversight.

---

Q163.

What is a privacy impact assessment (PIA)?

**Answer:** An evaluation of how a project or system collects, uses, and stores personal data and what risks exist for individuals' privacy rights.

*Example:* Before launching a mobile app collecting location data, a PIA identifies risks of unauthorized tracking and requires implementation of user consent controls.

---

Q164.

What is the concept of security by design?

**Answer:** Integrating security requirements and controls into systems and applications during the design phase rather than as an afterthought.

*Example:* A new ERP system is designed with role-based access, encrypted data fields, and audit logging from day one, preventing costly retrofitting later.

---

Q165.

What is the role of a Data Protection Officer (DPO)?

**Answer:** Under GDPR, a designated individual responsible for overseeing data protection strategy, ensuring compliance, and acting as a contact point for data subjects and authorities.

*Example:* The DPO reviews a new data sharing agreement with a marketing partner and requires additional DPA clauses before approval.

---

Q166.

What is third-party audit?

**Answer:** An independent assessment of an organization's security controls or practices by an external auditor to provide objective assurance.

*Example:* A SOC 2 Type II audit by an external CPA firm provides customers with independent assurance of the company's security, availability, and confidentiality controls.

---

Q167.

What is a SOC 2 report?

**Answer:** A third-party audit report on a service organization's controls related to security, availability, processing integrity, confidentiality, and privacy (Trust Service Criteria).

*Example:* Prospects require a SOC 2 Type II report before signing enterprise contracts, confirming the vendor's security controls have been operating effectively for 12 months.

---

## Domain 4: Additional Incident Management Questions

Q168.

What is a security incident vs. a security event?

**Answer:** An event is any observable action in the system; an incident is a confirmed event that has caused or may cause harm to information assets.

*Example:* Event: 5,000 authentication attempts. Incident: 50 successful logins using brute force credentials, confirmed by IR team investigation.

---

Q169.

What is the 72-hour GDPR breach notification rule?

**Answer:** GDPR Article 33 requires organizations to notify the supervisory authority within 72 hours of becoming aware of a personal data breach.

*Example:* A company discovers a database exposure on Tuesday at 9 AM; the DPO notifies the ICO by Friday at 9 AM to comply with the 72-hour rule.

---

Q170.

What is a cyber insurance policy?

**Answer:** Insurance coverage that helps organizations recover financial losses from cybersecurity incidents including breach response costs, business interruption, and legal liability.

*Example:* Cyber insurance covered \$3M of the \$5M breach response cost including forensics, legal fees, breach notifications, and credit monitoring for 50,000 customers.

---

Q171.

What is a major incident vs. a minor incident?

**Answer:** Major incidents have significant business impact (data loss, system outage, regulatory breach) requiring executive escalation. Minor incidents have limited impact manageable by the IT/security team.

*Example:* Major: ransomware encrypting ERP systems (executive + board notification required).  
Minor: phishing email blocked by spam filter (IT security handles without escalation).

---

Q172.

What is the purpose of a lessons learned session?

**Answer:** To capture what worked, what failed, and what should be improved in policies, tools, and training based on a real incident or exercise.

*Example:* Post-breach lessons learned: IR playbook lacked a ransomware-specific response section; DPO was not notified until day 3 violating GDPR 72-hour rule.

---

Q173.

What is a security incident communication plan?

**Answer:** Predefined protocols for notifying internal stakeholders, customers, regulators, and media during a security incident.

*Example:* Communication plan: CISO notifies CEO within 1 hour, Legal within 2 hours, Board within 4 hours, affected customers within 24 hours of breach confirmation.

---

Q174.

What is the concept of 'assume breach'?

**Answer:** A security mindset and architecture principle that assumes attackers are already inside the network, designing controls to limit damage and accelerate detection.

*Example:* Assume breach drives: microsegmentation to limit lateral movement, UBA to detect anomalies, and IR tabletops assuming initial access has already occurred.

---

Q175.

What is a forensic image?

**Answer:** A bit-for-bit copy of digital storage media that preserves all data (including deleted files and metadata) for forensic investigation.

*Example:* Before wiping a compromised server, the forensic team creates a DD image with MD5/SHA-256 hash verification stored in the evidence vault.

---

Q176.

What is volatile vs. non-volatile evidence?

**Answer:** Volatile evidence (RAM, network connections, running processes) is lost when power is cut. Non-volatile evidence (disk, logs) persists.

*Example:* IR best practice: capture RAM (volatile) and active network connections first before imaging the hard drive (non-volatile).

---

Q177.

What is the order of volatility in forensics?

**Answer:** The sequence for evidence collection prioritizing most volatile first: registers/CPU cache □ RAM □ network state □ running processes □ disk □ backup media.

*Example:* Forensic procedure captures in order: memory dump (1 min to lose) □ network connections □ disk image (persistent) — following RFC 3227 guidance.

---

Q178.

What is a security breach disclosure law?

**Answer:** Laws requiring organizations to notify affected individuals and/or government agencies when their personal data has been compromised.

*Example:* California's CCPA and CPRA require notification to California residents within 45 days of discovering a breach involving their personal information.

---

Q179.

What is the Cyber Kill Chain and how is it used defensively?

**Answer:** Lockheed Martin's 7-stage model of cyberattacks. Defenders use it to identify where controls can break the kill chain at the earliest possible stage.

*Example:* Placing email filtering at Delivery, HIPS at Exploitation, and EDR at Installation breaks the kill chain before the attacker reaches Actions on Objectives.

---

Q180.

What is threat intelligence sharing?

**Answer:** The practice of exchanging IoCs, TTPs, and threat actor information with trusted partners, ISACs, or government bodies to improve collective defense.

*Example:* A financial services company shares new ransomware IoCs with FS-ISAC within hours of detection, enabling 300 member firms to update their defenses.

---

Q181.

What is a security incident report?

**Answer:** A formal document recording the details of a security incident: timeline, affected systems, impact, response actions, evidence, and recommendations.

*Example:* Incident report for a phishing breach includes: attack vector, 3 compromised accounts, \$50K unauthorized transfer, recovery steps, and recommended MFA deployment.

---

Q182.

What is a hot wash?

**Answer:** An immediate, brief debrief conducted right after an incident or exercise to capture initial observations and urgent improvement actions.

*Example:* 30-minute hot wash after a ransomware tabletop: key findings — backup restoration took 3× longer than the RTO, and the legal escalation path was unclear.

---

Q183.

What is redundancy in BCP/DRP?

**Answer:** Duplicate systems, components, or data copies that can take over if primary systems fail, ensuring continuity of critical services.

*Example:* Critical payment systems use N+1 redundancy with active-active data centers and real-time database replication, achieving 99.99% uptime SLA.

---

Q184.

What is an emergency response team?

**Answer:** A dedicated group trained to respond to physical or cyber emergencies, coordinate evacuation, safety, and business continuity activities.

*Example:* The emergency response team activates when a fire triggers data center evacuation, following the BCP to redirect operations to the DR site within 2 hours.

---

Q185.

What is maximum tolerable downtime (MTD)?

**Answer:** The longest period a business function can be unavailable before causing irreversible harm to the organization.

*Example:* The trading platform's MTD is 4 hours; beyond this, regulatory violations and customer losses become catastrophic – driving a 2-hour RTO in the DR plan.

---

Q186.

What is a communication tree in incident response?

**Answer:** A predefined escalation and notification structure mapping who is notified, by whom, and within what timeframe during an incident.

*Example:* Communication tree: Analyst □ IR Lead (15 min) □ CISO (30 min) □ CEO/Legal (1 hour) □ Board (4 hours) □ Regulators (24-72 hours per legal requirement).

---

Q187.

What is the role of HR in incident management?

**Answer:** HR manages the human aspects of incidents: supporting employee notification, leading disciplinary actions for insider threats, and coordinating post-incident wellbeing.

*Example:* After an insider data theft by a terminated employee, HR leads the disciplinary review while Legal handles the criminal complaint filing.

---

## Bonus: General CISM Exam Tips & Concepts

Q188.

What is the CISM exam structure?

**Answer:** CISM has 150 questions covering 4 domains over 4 hours, requiring a score of 450/800 (scaled) to pass. It tests management and governance thinking, not technical implementation.

*Example:* CISM tip: answer from the perspective of an IS Manager making business decisions, not a technical engineer implementing solutions.

---

Q189.

What is the CISM candidate profile?

**Answer:** CISM is designed for IS managers, consultants, and senior security professionals with 5+ years of IS work experience (minimum 3 years in IS management).

*Example:* A CISO with 7 years of experience in security governance, risk, and program management is the ideal CISM candidate.

---

Q190.

What is the CISM experience requirement?

**Answer:** Candidates must have a minimum of 5 years of IS work experience, with at least 3 years in IS management across 3 or more CISM domains, verified within 10 years of passing.

*Example:* Experience substitutions: CISA/CISSP certification waives 1 year; a graduate IS degree waives 1 year of the total 5-year requirement.

---

Q191.

What is the ISACA Code of Professional Ethics?

**Answer:** A set of principles guiding ISACA members to act with integrity, competence, due diligence, and confidentiality in their professional roles.

*Example:* A CISM professional who discovers a client's unreported breach must advise the client to disclose it per legal obligations – guided by the ISACA ethics code.

---

Q192.

What is continuing professional education (CPE) for CISM?

**Answer:** CISM holders must earn 120 CPE hours over a 3-year period (minimum 20/year) and pay an annual maintenance fee to maintain the certification.

*Example:* A CISM holder attends ISACA conferences, webinars, and completes ISACA courses – each hour of activity equals 1 CPE credit toward the 120-hour requirement.

---

Q193.

What is the primary focus of CISM vs. CISSP?

**Answer:** CISM focuses on managing and governing IS programs from a business perspective. CISSP is broader, covering deep technical and architectural knowledge across 8 domains.

*Example:* CISM question: 'What should the IS manager do FIRST after a breach?' CISSP question might focus on specific cryptographic protocols or network architectures.

---

#### Q194.

What is the 'best answer' approach for CISM exam?

**Answer:** CISM favors answers that address risk management, business alignment, governance, and program-level decisions over purely technical or reactive answers.

*Example:* If a question asks what to do after discovering a vulnerability, CISM answer = 'Perform a risk assessment to determine business impact' vs. 'Immediately patch the system.'

---

#### Q195.

What is ISACA's definition of IS governance?

**Answer:** The set of responsibilities and practices exercised by the board and executive management to provide strategic direction and ensure IS objectives are achieved.

*Example:* ISACA distinguishes governance (board-level direction and oversight) from management (CISO-level execution and operations).

---

#### Q196.

What is a CISM job practice area?

**Answer:** ISACA-defined areas of IS management knowledge: IS Governance, Risk Management, IS Program, and Incident Management — the four CISM domains.

*Example:* CISM domain weights: Domain 1 (17%), Domain 2 (20%), Domain 3 (33%), Domain 4 (30%) — IS Program and Incident Management are the highest-weighted.

---

#### Q197.

What are the CISM exam registration steps?

**Answer:** 1. Create ISACA account, 2. Register for CISM exam online, 3. Pay exam fee, 4. Schedule at Pearson VUE test center or online proctored, 5. Study and pass, 6. Apply for certification with experience verification.

*Example:* After passing the exam, candidates have 5 years to submit the experience verification form to ISACA to formally receive the CISM certification.

---



# CISM Study Tips & Exam Strategy

---

**Think Like a Manager:** CISM tests IS management decisions, not technical implementations. Always choose the answer a business-aligned IS manager would make.

**Risk-First Approach:** When unsure between options, the answer that addresses RISK ASSESSMENT or RISK MANAGEMENT first is usually correct.

**Governance Over Technical:** If given a choice between implementing a technical control and establishing a policy/governance process, governance usually comes first.

**Read ALL Options:** CISM questions have one BEST answer among plausible choices. Read all 4 options before selecting to avoid choosing a 'good' but not 'best' answer.

**Know the 4 Domains:** Domain 3 (IS Program) = 33% and Domain 4 (Incident Mgmt) = 30% — together 63% of the exam. Focus your study time accordingly.

**Practice Scenario Questions:** CISM uses scenario-based questions. Practice identifying the IS manager's FIRST or BEST action in complex situations.

**Time Management:** 150 questions in 240 minutes = 1.6 min/question. Flag difficult questions and return to them; don't spend too long on any single question.

**Exam Day:** Arrive 30 min early (or log in 15 min early for remote). Bring valid government ID. You may use a notepad for scratch paper at the test center.